

2 Security Standards: Administrative Safeguards



security controls already in place, an accurate and thorough risk analysis, and a series of documented solutions derived from a number of factors unique to each covered entity.

STANDARD § 164.308(a)(1)

Security Management Process

The first standard under Administrative Safeguards section is the Security Management Process. This standard requires covered entities to:

“Implement policies and procedures to prevent, detect, contain and correct security violations.”

The purpose of this standard is to establish the administrative processes and procedures that a covered entity will use to implement the security program in its environment. There are four implementation specifications in the Security Management Process standard.

1. Risk Analysis (Required)
2. Risk Management (Required)
3. Sanction Policy (Required)
4. Information System Activity Review (Required)

NOTE: For a more detailed discussion of “addressable” and “required” implementation specifications, see the first paper in this series, “Security 101 for Covered Entities.”

The Importance of Risk Analysis and Risk Management

Risk analysis and risk management are critical to a covered entity’s Security Rule compliance efforts. Both are standard information security processes that have already been adopted by some organizations within the health care industry.

As stated in the responses to public comment in the preamble to the Security Rule, the Security Management Process standard and associated implementation specifications “*form the foundation upon which an entity’s necessary security activities are built.*” The results from the risk analysis and risk management processes will become the baseline for security processes within covered entities.

This paper provides a general understanding of risk analysis and risk management concepts and processes. CMS will include a more detailed discussion of risk analysis and risk management in paper 6 in the HIPAA Security Series titled, “Basics of Risk Analysis and Risk Management.”

NOTE: Risk analysis and risk management serve as tools to assist in the development of a covered entity’s strategy to protect the confidentiality, integrity, and availability of EPHI.

2 Security Standards: Administrative Safeguards



1. RISK ANALYSIS (R) - § 164.308(a)(1)(ii)(A)

The Risk Analysis implementation specification requires covered entities to:

“Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity.”

In general, a risk analysis can be viewed as:

- ☐ The process of identifying potential security risks, and
- ☐ Determining the probability of occurrence and magnitude of risks.

Sample questions for covered entities to consider:

- ✓ How does EPHI flow throughout the organization? This includes EPHI that is created, received, maintained or transmitted by the covered entity.
- ✓ What are the less obvious sources of EPHI? Has the organization considered portable devices like PDAs?
- ✓ What are the external sources of EPHI? For example, do vendors or consultants create, receive, maintain or transmit EPHI?
- ✓ What are the human, natural, and environmental threats to information systems that contain EPHI?

2. RISK MANAGEMENT (R) - § 164.308(a)(1)(ii)(B)

Risk Management is a required implementation specification. It requires an organization to make decisions about how to address security risks and vulnerabilities. The Risk Management implementation specification states that covered entities must:

“Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with §164.306(a).”

Risk management is the process used to identify and implement security measures to reduce risk to a reasonable and appropriate level within the covered entity based on the covered entity’s circumstances. The measures implemented to comply with this required implementation specification must also allow the covered entity to comply with §

2 Security Standards: Administrative Safeguards



164.306(a) of the Security Standards: General Rules. Covered entities will want to answer some basic questions when planning their risk management process.

Sample questions for covered entities to consider:

- ✓ What security measures are already in place to protect EPHI (i.e., safeguards)?
- ✓ Is executive leadership and/or management involved in risk management and mitigation decisions?
- ✓ Are security processes being communicated throughout the organization?
- ✓ Does the covered entity need to engage other resources to assist in risk management?

In general, a covered entity will want to make sure its risk management strategy takes into account the characteristics of its environment including the factors at § 164.306(b)(2), which are listed on page 2 of this paper. These factors will help the covered entity to determine what potential security measures are reasonable and appropriate for its environment.

NOTE: Covered entities must ensure that the risk analysis and risk management processes are on-going and dynamic processes that can change as the environment or operations change.

3. SANCTION POLICY (R) - § 164.308(a)(1)(ii)(C)

Another implementation specification in the Security Management Process is the Sanction Policy. It requires covered entities to:

“Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity.”

Appropriate sanctions must be in place so that workforce members understand the consequences of failing to comply with security policies and procedures, to deter noncompliance.

Sample questions for covered entities to consider:

- ✓ Does the covered entity have existing sanction policies and procedures to meet the requirements of this implementation specification? If not, can

2 Security Standards: Administrative Safeguards



existing sanction policies be modified to include language relating to violations of these policies and procedures?

- ✓ Does the organization require employees to sign a statement of adherence to security policy and procedures (e.g., as part of the employee handbook or confidentiality statement) as a prerequisite to employment?
- ✓ Does the statement of adherence to security policies and procedures state that the workforce member acknowledges that violations of security policies and procedures may lead to disciplinary action, for example, up to and including termination?
- ✓ Does the sanction policy provide examples of potential violations of policy and procedures?
- ✓ Does the sanction policy adjust the disciplinary action based on the severity of the violation?

NOTE: A covered entity's sanction policy should reinforce its security policies and procedures.

4. INFORMATION SYSTEM ACTIVITY REVIEW (R) - § 164.308(a)(1)(ii)(D)

The Security Management Process standard also includes the Information System Activity Review implementation specification. This required implementation specification states that covered entities must:

“Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.”

The information system activity review enables covered entities to determine if any EPHI is used or disclosed in an inappropriate manner.

Information system activity review procedures may be different for each covered entity. The procedure should be customized to meet the covered entity's risk management strategy and take into account the capabilities of all information systems with EPHI.

2 Security Standards: Administrative Safeguards



Sample questions for covered entities to consider:

- ✓ What are the audit and activity review functions of the current information systems?
- ✓ Are the information systems functions adequately used and monitored to promote continual awareness of information system activity?
- ✓ What logs or reports are generated by the information systems?
- ✓ Is there a policy that establishes what reviews will be conducted?
- ✓ Is there a procedure that describes specifics of the reviews?

NOTE: The Information System Activity Review implementation specification should also promote continual awareness of any information system activity that could suggest a security incident.

STANDARD § 164.308(a)(2)

Assigned Security Responsibility

The second standard in the Administrative Safeguards section is Assigned Security Responsibility. There are no separate implementation specifications for this standard. The standard requires that covered entities:

“Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart [the Security Rule] for the entity.”

The purpose of this standard is to identify who will be operationally responsible for assuring that the covered entity complies with the Security Rule. Covered entities should be aware of the following when assigning security responsibility:

- ☐ This requirement is comparable to the Privacy Rule standard at §164.530(a)(1), Personnel Designations, which requires all covered entities to designate a Privacy Official.
- ☐ The Security Official and Privacy Official can be the same person, but are not required to be.

2 Security Standards: Administrative Safeguards



- ☐ While one individual must be designated as having overall responsibility, other individuals in the covered entity may be assigned specific security responsibilities (e.g., facility security or network security).

When making this decision covered entities should consider some basic questions.

Sample questions for covered entities to consider:

- ✓ Would it serve the organization's needs to designate the same individual as both the Privacy and Security Official (for example, in a small provider office)?
- ✓ Has the organization agreed upon, and clearly identified and documented, the responsibilities of the Security Official?
- ✓ How are the roles and responsibilities of the Security Official crafted to reflect the size, complexity and technical capabilities of the organization?

STANDARD § 164.308(a)(3)

Workforce Security

The third standard is Workforce Security, which states that covered entities must:

“Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under [the Information Access Management standard], and to prevent those workforce members who do not have access under [the Information Access Management standard] from obtaining access to electronic protected health information.”

Within a covered entity's environment, workforce members that need access to EPHI to carry out their duties must be identified. For each workforce member, or job function, the covered entity must identify the EPHI that is needed, when it is needed, and make reasonable efforts to control access to the EPHI. This will also include identification of the computer systems and applications that provide access to the EPHI. Covered entities must provide only the minimum necessary access to EPHI that is required for a workforce member to do his or her job.

Within Workforce Security there are three addressable implementation specifications.

1. Authorization and/or Supervision (Addressable)

2 Security Standards: Administrative Safeguards



2. Workforce Clearance Procedure (Addressable)
3. Termination Procedures (Addressable)

1. AUTHORIZATION AND/OR SUPERVISION (A) – § 164.308(a)(3)(ii)(A)

Where the Authorization and/or Supervision implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must:

“Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed.”

Authorization is the process of determining whether a particular user (or a computer system) has the right to carry out a certain activity, such as reading a file or running a program. Implementation of this addressable implementation specification will vary among covered entities, depending upon the size and complexity of the workforce, and the information systems that contain EPHI. For example, in a very small provider office, all staff members may need to access all EPHI in their information system, since they may perform multiple functions. In this case, the covered entity might document the reasons for implementing policies and procedures allowing this kind of global access. If the documented rationale is reasonable and appropriate, this may be an acceptable approach.

NOTE: The Authorization and/or Supervision implementation specification provides the necessary checks and balances to ensure that all members of the workforce have appropriate access (or, in some cases, no access) to EPHI.

To determine the most reasonable and appropriate authorization and/or supervision procedures, covered entities may want to ask some basic questions about existing policies and procedures.

Sample questions for covered entities to consider:

- ✓ Are detailed job descriptions used to determine what level of access the person holding the position should have to EPHI?
- ✓ Who has or should have the authority to determine who can access EPHI, e.g., supervisors or managers?
- ✓ Are there similar existing processes used for paper records that could be used as an example for the EPHI?

2 Security Standards: Administrative Safeguards



Covered entities should review the authorization and supervision policies already present in the organization's current operating environment. Depending on the existing policies, covered entities may need to reinforce them, make modifications for EPHI, and/or develop corresponding documentation.

2. WORKFORCE CLEARANCE PROCEDURE (A) - § 164.308(a)(3)(ii)(B)

Covered entities need to address whether all members of the workforce with authorized access to EPHI receive appropriate clearances. Where the Workforce Clearance Procedure implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must:

“Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate.”

In other words, the clearance process must establish the procedures to verify that a workforce member does in fact have the appropriate access for their job function. A covered entity may choose to perform this type of screening procedure separate from or as a part of the authorization and/or supervision procedure.

Sample questions for covered entities to consider:

- ✓ Are there existing procedures for determining that the appropriate workforce members have access to the necessary information?
- ✓ Are the procedures used consistently within the organization when determining access of related workforce job functions?

3. TERMINATION PROCEDURES (A) - § 164.308(a)(3)(ii)(C)

Where the Termination Procedures implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must:

“Implement procedures for terminating access to electronic protected health information when the employment of a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) [the Workforce Clearance Procedure] of this section.”

Termination procedures must be implemented to remove access privileges when an employee, contractor, or other individual previously entitled to access information no longer has these privileges. Whether the employee leaves the organization voluntarily or involuntarily, procedures to terminate access must be in place.

2 Security Standards: Administrative Safeguards



The same process that is implemented for termination should also be used to change access levels if an employee's job description changes to require more or less access to EPHI. The procedures should also address the complexity of the organization and the sophistication of associated information systems.

Sample questions for covered entities to consider:

- ✓ Do the termination policies and procedures assign responsibility for removing information system and/or physical access?
- ✓ Do the policies and procedures include timely communication of termination actions to insure that the termination procedures are appropriately followed?

STANDARD § 164.308(a)(4)

Information Access Management

The fourth standard in the Administrative Safeguards section is Information Access Management. Covered entities are required to:

“Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part [the Privacy Rule].”

Restricting access to only those persons and entities with a need for access is a basic tenet of security. By implementing this standard, the risk of inappropriate disclosure, alteration, or destruction of EPHI is minimized. Covered entities must determine those persons and/or entities that need access to EPHI within their environment.

NOTE: The Information Access Management implementation specifications are closely related to the implementation specifications under the Workforce Security standard.

Compliance with this standard should support a covered entity's compliance with the HIPAA Privacy Rule minimum necessary requirements, which requires covered entities to evaluate their practices and enhance safeguards as needed to limit unnecessary or inappropriate access to and disclosure of protected health information. To better understand this standard, covered entities should review the minimum necessary standard of the HIPAA Privacy Rule. See 45 CFR 164.502(b) and 164.514(d).

The Information Access Management standard has three implementation specifications.

1. Isolating Health Care Clearinghouse Functions (Required)



2 Security Standards: Administrative Safeguards



2. Access Authorization (Addressable)
3. Access Establishment and Modification (Addressable)

1. ISOLATING HEALTH CARE CLEARINGHOUSE FUNCTIONS (R) – § 164.308(a)(4)(ii)(A)

The Isolating Health Care Clearinghouse Functions implementation specification states:

“If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization.”

This implementation specification only applies in the situation where a health care clearinghouse is part of a larger organization. In these situations, the health care clearinghouse is responsible for protecting the EPHI that it is processing.

Sample questions for covered entities to consider:

- ✓ Does the larger organization perform health care clearinghouse functions?
- ✓ If health care clearinghouse functions are performed, are policies and procedures implemented to protect EPHI from the other functions of the larger organization?
- ✓ Are additional technical safeguards needed to separate EPHI in information systems, used by the health care clearinghouse, to protect against unauthorized access by the larger organization?

2. ACCESS AUTHORIZATION (A) - § 164.308(a)(4)(ii)(B)

In the Workforce Security standard portion of this paper, authorization was defined as the act of determining whether a particular user (or computer system) has the right, based on job function or responsibilities, to carry out a certain activity, such as reading a file or running a program. Where this implementation standard is a reasonable and appropriate safeguard for a covered entity, the covered entity must:

“Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process, or other mechanism.”

2 Security Standards: Administrative Safeguards



Once the covered entity has determined that the person or system is authorized, there are numerous ways to grant access to EPHI. In general, a covered entity's policies and procedures must identify who has authority to grant access privileges. It must also state the process for granting access. To create and document policies and procedures to grant access, covered entities should address the following questions.

Sample questions for covered entities to consider:

- ✓ How is authorization documented? How can it be used to grant access?
- ✓ Are the policies and procedures for granting access consistent with applicable requirements of the Privacy Rule?
- ✓ Have appropriate authorization and clearance procedures, as specified in workforce security, been performed prior to granting access?
- ✓ Are access rules specific to applications and business requirements? For example, do different workforce members require different levels of access based on job function?
- ✓ Is there a technical process in place, such as creating unique user name and an authentication process, when granting access to a workforce member?

Once a covered entity has clearly defined who should get access to what EPHI and under what circumstances, it must consider how access is established and modified.

3. ACCESS ESTABLISHMENT AND MODIFICATION (A) - § 164.308(a)(4)(ii)(C)

Where the Access Establishment and Modification implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must:

“Implement policies and procedures that, based upon the entity’s access authorization policies, establish, document, review, and modify a user’s right of access to a workstation, transaction, program, or process.”

This means that a covered entity must implement and manage the creation and modification of access privileges to workstations, transactions, programs or processes. Responsibility for this function may be assigned to a specific individual or individuals, which also may be responsible for terminating access privileges for workforce members.

2 Security Standards: Administrative Safeguards



Covered entities must evaluate existing procedures, update them (if needed), and document procedures as necessary.

Sample questions for covered entities to consider:

- ✓ Are policies and procedures in place for establishing access and modifying access?
- ✓ Are system access policies and procedures documented and updated as necessary?
- ✓ Do members of management or other workforce members periodically review the list of persons with access to EPHI to ensure they are valid and consistent with those authorized?

STANDARD § 164.308(a)(5)

Security Awareness and Training

Regardless of the Administrative Safeguards a covered entity implements, those safeguards will not protect the EPHI if the workforce is unaware of its role in adhering to and enforcing them. Many security risks and vulnerabilities within covered entities are internal. This is why the next standard, Security Awareness and Training, is so important.

Specifically, the Security Awareness and Training standard states that covered entities must:

“Implement a security awareness and training program for all members of its workforce (including management).”

Security training for all new and existing members of the covered entity’s workforce is required by the compliance date of the Security Rule. In addition, periodic retraining should be given whenever environmental or operational changes affect the security of EPHI. Changes may include: new or updated policies and procedures; new or upgraded software or hardware; new security technology; or even changes in the Security Rule.

The Security Awareness and Training standard has four implementation specifications.

1. Security Reminders (Addressable)
2. Protection from Malicious Software (Addressable)
3. Log-in Monitoring (Addressable)
4. Password Management (Addressable)

2 Security Standards: Administrative Safeguards



1. SECURITY REMINDERS (A) - § 164.308(a)(5)(ii)(A)

Where this implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must implement:

“Periodic security updates.”

There are many types of security reminders that covered entities may choose to implement. Examples might include notices in printed or electronic form, agenda items and specific discussion topics at monthly meetings, focused reminders posted in affected areas, as well as formal retraining on security policies and procedures. Covered entities should look at how they currently remind the workforce of current policies and procedures, and then decide whether these practices are reasonable and appropriate or if other forms of security reminders are needed.

NOTE: Covered entities must document the security reminders they implement. Documentation could include the type of reminder, its message, and the date it was implemented.

2. PROTECTION FROM MALICIOUS SOFTWARE (A) - § 164.308(a)(5)(ii)(B)

One important security measure that employees may need to be reminded of is security software that is used to protect against malicious software. Where this implementation specification is a reasonable and appropriate safeguard for a covered entity, the covered entity must implement:

“Procedures for guarding against, detecting, and reporting malicious software.”

Malicious software can be thought of as any program that harms information systems, such as viruses, Trojan horses or worms. As a result of an unauthorized infiltration, EPHI and other data can be damaged or destroyed, or at a minimum, require expensive and time-consuming repairs.

NOTE: Malicious software that successfully invades information systems can cause significant damage.

Malicious software is frequently brought into an organization through email attachments, and programs that are downloaded from the Internet. Under the Security Awareness and Training standard, the workforce must also be trained regarding its role in protecting against malicious software, and system protection capabilities. It is important to note that training must be an ongoing process for all organizations.

Guidance on Risk Analysis Requirements under the HIPAA Security Rule

Introduction

The Office for Civil Rights (OCR) is responsible for issuing annual guidance on the provisions in the HIPAA Security Rule.¹ (45 C.F.R. §§ 164.302 – 318.) This series of guidances will assist organizations² in identifying and implementing the most effective and appropriate administrative, physical, and technical safeguards to secure electronic protected health information (e-PHI). The guidance materials will be developed with input from stakeholders and the public, and will be updated as appropriate.

We begin the series with the risk analysis requirement in § 164.308(a)(1)(ii)(A). Conducting a risk analysis is the first step in identifying and implementing safeguards that comply with and carry out the standards and implementation specifications in the Security Rule. Therefore, a risk analysis is foundational, and must be understood in detail before OCR can issue meaningful guidance that specifically addresses safeguards and technologies that will best protect electronic health information.

The guidance is not intended to provide a one-size-fits-all blueprint for compliance with the risk analysis requirement. Rather, it clarifies the expectations of the Department for organizations working to meet these requirements.³ An organization should determine the most appropriate way to achieve compliance, taking into account the characteristics of the organization and its environment.

We note that some of the content contained in this guidance is based on recommendations of the National Institute of Standards and Technology (NIST). NIST, a federal agency, publishes freely available material in the public domain, including guidelines.⁴ Although only federal agencies are required to follow guidelines set by NIST, the guidelines represent the industry standard for good business practices with respect to standards for securing e-PHI. Therefore, non-federal organizations may find their content valuable when developing and performing compliance activities.

All e-PHI created, received, maintained or transmitted by an organization is subject to the Security Rule. The Security Rule requires entities to evaluate risks and vulnerabilities in their environments and to implement reasonable and appropriate security measures to

¹ Section 13401(c) of the Health Information Technology for Economic and Clinical (HITECH) Act.

² As used in this guidance the term “organizations” refers to covered entities and business associates. The guidance will be updated following implementation of the final HITECH regulations.

³ The HIPAA Security Rule: Health Insurance Reform: Security Standards, February 20, 2003, 68 FR 8334.

⁴ The 800 Series of Special Publications (SP) are available on the Office for Civil Rights’ website – specifically, *SP 800-30 - Risk Management Guide for Information Technology Systems*. (<http://www.hhs.gov/ocr/privacy/hipaa/administrative/securityrule/securityruleguidance.html>.)

protect against reasonably anticipated threats or hazards to the security or integrity of e-PHI. Risk analysis is the first step in that process.

We understand that the Security Rule does not prescribe a specific risk analysis methodology, recognizing that methods will vary dependent on the size, complexity, and capabilities of the organization. Instead, the Rule identifies risk analysis as the foundational element in the process of achieving compliance, and it establishes several objectives that any methodology adopted must achieve.

Risk Analysis Requirements under the Security Rule

The Security Management Process standard in the Security Rule requires organizations to “[i]mplement policies and procedures to prevent, detect, contain, and correct security violations.” (45 C.F.R. § 164.308(a)(1).) Risk analysis is one of four required implementation specifications that provide instructions to implement the Security Management Process standard. Section 164.308(a)(1)(ii)(A) states:

RISK ANALYSIS (Required).

Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the [organization].

The following questions adapted from NIST Special Publication (SP) 800-66⁵ are examples organizations could consider as part of a risk analysis. These sample questions are not prescriptive and merely identify issues an organization may wish to consider in implementing the Security Rule:

- Have you identified the e-PHI within your organization? This includes e-PHI that you create, receive, maintain or transmit.
- What are the external sources of e-PHI? For example, do vendors or consultants create, receive, maintain or transmit e-PHI?
- What are the human, natural, and environmental threats to information systems that contain e-PHI?

In addition to an express requirement to conduct a risk analysis, the Rule indicates that risk analysis is a necessary tool in reaching substantial compliance with many other standards and implementation specifications. For example, the Rule contains several implementation specifications that are labeled “addressable” rather than “required.” (68 FR 8334, 8336 (Feb. 20, 2003).) An addressable implementation specification is not optional; rather, if an organization determines that the implementation specification is not reasonable and appropriate, the organization must document why it is not reasonable and

⁵ See NIST SP 800-66, Section #4 "Considerations When Applying the HIPAA Security Rule." Available at <http://www.hhs.gov/ocr/privacy/hipaa/administrative/securityrule/nist80066.pdf>

appropriate and adopt an equivalent measure if it is reasonable and appropriate to do so. (See 68 FR 8334, 8336 (Feb. 20, 2003); 45 C.F.R. § 164.306(d)(3).)

The outcome of the risk analysis process is a critical factor in assessing whether an implementation specification or an equivalent measure is reasonable and appropriate. Organizations should use the information gleaned from their risk analysis as they, for example:

- Design appropriate personnel screening processes. (45 C.F.R. § 164.308(a)(3)(ii)(B).)
- Identify what data to backup and how. (45 C.F.R. § 164.308(a)(7)(ii)(A).)
- Decide whether and how to use encryption. (45 C.F.R. §§ 164.312(a)(2)(iv) and (e)(2)(ii).)
- Address what data must be authenticated in particular situations to protect data integrity. (45 C.F.R. § 164.312(c)(2).)
- Determine the appropriate manner of protecting health information transmissions. (45 C.F.R. § 164.312(e)(1).)

Important Definitions

Unlike “availability”, “confidentiality” and “integrity”, the following terms are not expressly defined in the Security Rule. The definitions provided in this guidance, which are consistent with common industry definitions, are provided to put the risk analysis discussion in context. These terms do not modify or update the Security Rule and should not be interpreted inconsistently with the terms used in the Security Rule.

Vulnerability

Vulnerability is defined in NIST Special Publication (SP) 800-30 as “[a] *flaw or weakness in system security procedures, design, implementation, or internal controls that could be exercised (accidentally triggered or intentionally exploited) and result in a security breach or a violation of the system’s security policy.*”

Vulnerabilities, whether accidentally triggered or intentionally exploited, could potentially result in a security incident, such as inappropriate access to or disclosure of e-PHI. Vulnerabilities may be grouped into two general categories, technical and non-technical. Non-technical vulnerabilities may include ineffective or non-existent policies, procedures, standards or guidelines. Technical vulnerabilities may include: holes, flaws or weaknesses in the development of information systems; or incorrectly implemented and/or configured information systems.

Threat

An adapted definition of threat, from NIST SP 800-30, is “[t]he *potential for a person or thing to exercise (accidentally trigger or intentionally exploit) a specific vulnerability.*”

There are several types of threats that may occur within an information system or operating environment. Threats may be grouped into general categories such as natural, human, and environmental. Examples of common threats in each of these general categories include:

- Natural threats such as floods, earthquakes, tornadoes, and landslides.
- Human threats are enabled or caused by humans and may include intentional (e.g., network and computer based attacks, malicious software upload, and unauthorized access to e-PHI) or unintentional (e.g., inadvertent data entry or deletion and inaccurate data entry) actions.
- Environmental threats such as power failures, pollution, chemicals, and liquid leakage.

Risk

An adapted definition of risk, from NIST SP 800-30, is:

“The net mission impact considering (1) the probability that a particular [threat] will exercise (accidentally trigger or intentionally exploit) a particular [vulnerability] and (2) the resulting impact if this should occur . . . [R]isks arise from legal liability or mission loss due to—

- 1. Unauthorized (malicious or accidental) disclosure, modification, or destruction of information*
- 2. Unintentional errors and omissions*
- 3. IT disruptions due to natural or man- made disasters*
- 4. Failure to exercise due care and diligence in the implementation and operation of the IT system.”*

Risk can be understood as a function of 1) the likelihood of a given threat triggering or exploiting a particular vulnerability, and 2) the resulting impact on the organization. This means that risk is not a single factor or event, but rather it is a combination of factors or events (threats and vulnerabilities) that, if they occur, may have an adverse impact on the organization.

Elements of a Risk Analysis

There are numerous methods of performing risk analysis and there is no single method or “best practice” that guarantees compliance with the Security Rule. Some examples of steps that might be applied in a risk analysis process are outlined in NIST SP 800-30.⁶

The remainder of this guidance document explains several elements a risk analysis must incorporate, regardless of the method employed.

⁶ Available at <http://www.hhs.gov/ocr/privacy/hipaa/administrative/securityrule/nist800-30.pdf>.

Scope of the Analysis

The scope of risk analysis that the Security Rule encompasses includes the potential risks and vulnerabilities to the confidentiality, availability and integrity of all e-PHI that an organization creates, receives, maintains, or transmits. (45 C.F.R. § 164.306(a).) This includes e-PHI in all forms of electronic media, such as hard drives, floppy disks, CDs, DVDs, smart cards or other storage devices, personal digital assistants, transmission media, or portable electronic media. Electronic media includes a single workstation as well as complex networks connected between multiple locations. Thus, an organization's risk analysis should take into account all of its e-PHI, regardless of the particular electronic medium in which it is created, received, maintained or transmitted or the source or location of its e-PHI.

Data Collection

An organization must identify where the e-PHI is stored, received, maintained or transmitted. An organization could gather relevant data by: reviewing past and/or existing projects; performing interviews; reviewing documentation; or using other data gathering techniques. The data on e-PHI gathered using these methods must be documented. (See 45 C.F.R. §§ 164.308(a)(1)(ii)(A) and 164.316(b)(1).)

Identify and Document Potential Threats and Vulnerabilities

Organizations must identify and document reasonably anticipated threats to e-PHI. (See 45 C.F.R. §§ 164.306(a)(2) and 164.316(b)(1)(ii).) Organizations may identify different threats that are unique to the circumstances of their environment. Organizations must also identify and document vulnerabilities which, if triggered or exploited by a threat, would create a risk of inappropriate access to or disclosure of e-PHI. (See 45 C.F.R. §§ 164.308(a)(1)(ii)(A) and 164.316(b)(1)(ii).)

Assess Current Security Measures

Organizations should assess and document the security measures an entity uses to safeguard e-PHI, whether security measures required by the Security Rule are already in place, and if current security measures are configured and used properly. (See 45 C.F.R. §§ 164.306(b)(1), 164.308(a)(1)(ii)(A), and 164.316(b)(1).)

The security measures implemented to reduce risk will vary among organizations. For example, small organizations tend to have more control within their environment. Small organizations tend to have fewer variables (i.e. fewer workforce members and information systems) to consider when making decisions regarding how to safeguard e-PHI. As a result, the appropriate security measures that reduce the likelihood of risk to

the confidentiality, availability and integrity of e-PHI in a small organization may differ from those that are appropriate in large organizations.⁷

Determine the Likelihood of Threat Occurrence

The Security Rule requires organizations to take into account the probability of potential risks to e-PHI. (See 45 C.F.R. § 164.306(b)(2)(iv).) The results of this assessment, combined with the initial list of threats, will influence the determination of which threats the Rule requires protection against because they are “reasonably anticipated.”

The output of this part should be documentation of all threat and vulnerability combinations with associated likelihood estimates that may impact the confidentiality, availability and integrity of e-PHI of an organization. (See 45 C.F.R. §§ 164.306(b)(2)(iv), 164.308(a)(1)(ii)(A), and 164.316(b)(1)(ii).)

Determine the Potential Impact of Threat Occurrence

The Rule also requires consideration of the “criticality,” or impact, of potential risks to confidentiality, integrity, and availability of e-PHI. (See 45 C.F.R. § 164.306(b)(2)(iv).) An organization must assess the magnitude of the potential impact resulting from a threat triggering or exploiting a specific vulnerability. An entity may use either a qualitative or quantitative method or a combination of the two methods to measure the impact on the organization.

The output of this process should be documentation of all potential impacts associated with the occurrence of threats triggering or exploiting vulnerabilities that affect the confidentiality, availability and integrity of e-PHI within an organization. (See 45 C.F.R. §§ 164.306(a)(2), 164.308(a)(1)(ii)(A), and 164.316(b)(1)(ii).)

Determine the Level of Risk

Organizations should assign risk levels for all threat and vulnerability combinations identified during the risk analysis. The level of risk could be determined, for example, by analyzing the values assigned to the likelihood of threat occurrence and resulting impact of threat occurrence. The risk level determination might be performed by assigning a risk level based on the average of the assigned likelihood and impact levels.

The output should be documentation of the assigned risk levels and a list of corrective actions to be performed to mitigate each risk level. (See 45 C.F.R. §§ 164.306(a)(2), 164.308(a)(1)(ii)(A), and 164.316(b)(1).)

Finalize Documentation

⁷ For more information on methods smaller entities might employ to achieve compliance with the Security Rule, see #7 in the Center for Medicare and Medicaid Services’ (CMS) Security Series papers, titled “Implementation for the Small Provider.” Available at <http://www.hhs.gov/ocr/privacy/hipaa/administrative/securityrule/smallprovider.pdf>.

The Security Rule requires the risk analysis to be documented but does not require a specific format. (See 45 C.F.R. § 164.316(b)(1).) The risk analysis documentation is a direct input to the risk management process.

Periodic Review and Updates to the Risk Assessment

The risk analysis process should be ongoing. In order for an entity to update and document its security measures “as needed,” which the Rule requires, it should conduct continuous risk analysis to identify when updates are needed. (45 C.F.R. §§ 164.306(e) and 164.316(b)(2)(iii).) The Security Rule does not specify how frequently to perform risk analysis as part of a comprehensive risk management process. The frequency of performance will vary among covered entities. Some covered entities may perform these processes annually or as needed (e.g., bi-annual or every 3 years) depending on circumstances of their environment.

A truly integrated risk analysis and management process is performed as new technologies and business operations are planned, thus reducing the effort required to address risks identified after implementation. For example, if the covered entity has experienced a security incident, has had change in ownership, turnover in key staff or management, is planning to incorporate new technology to make operations more efficient, the potential risk should be analyzed to ensure the e-PHI is reasonably and appropriately protected. If it is determined that existing security measures are not sufficient to protect against the risks associated with the evolving threats or vulnerabilities, a changing business environment, or the introduction of new technology, then the entity must determine if additional security measures are needed. Performing the risk analysis and adjusting risk management processes to address risks in a timely manner will allow the covered entity to reduce the associated risks to reasonable and appropriate levels.⁸

In Summary

Risk analysis is the first step in an organization’s Security Rule compliance efforts. Risk analysis is an ongoing process that should provide the organization with a detailed understanding of the risks to the confidentiality, integrity, and availability of e-PHI.

Resources

The Security Series papers available on the Office for Civil Rights (OCR) website, <http://www.hhs.gov/ocr/hipaa>, contain a more detailed discussion of tools and methods available for risk analysis and risk management, as well as other Security Rule

⁸ For more information on methods smaller entities might employ to achieve compliance with the Security Rule, see #6 in the Center for Medicare and Medicaid Services’ (CMS) Security Series papers, titled “Basics of Risk Analysis and Risk Management.” Available at <http://www.hhs.gov/ocr/privacy/hipaa/administrative/securityrule/riskassessment.pdf>.

compliance requirements. Visit <http://www.hhs.gov/ocr/hipaa> for the latest guidance, FAQs and other information on the Security Rule.

Several other federal and non-federal organizations have developed materials that might be helpful to covered entities seeking to develop and implement risk analysis and risk management strategies. The Department of Health and Human Services does not endorse or recommend any particular risk analysis or risk management model. The documents referenced below do not constitute legally binding guidance for covered entities, nor does adherence to any or all of the standards contained in these materials prove substantial compliance with the risk analysis requirements of the Security Rule. Rather, the materials are presented as examples of frameworks and methodologies that some organizations use to guide their risk analysis efforts.

The National Institute of Standards and Technology (NIST), an agency of the United States Department of Commerce, is responsible for developing information security standards for federal agencies. NIST has produced a series of Special Publications, available at <http://csrc.nist.gov/publications/PubsSPs.html>, which provide information that is relevant to information technology security. These papers include:

- Guide to Technical Aspects of Performing Information Security Assessments (SP800-115)
- Information Security Handbook: A Guide for Managers (SP800-100; Chapter 10 provides a Risk Management Framework and details steps in the risk management process)
- An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule (SP800-66; Part 3 links the NIST Risk Management Framework to components of the Security Rule)
- A draft publication, Managing Risk from Information Systems (SP800-39)

The Office of the National Coordinator for Health Information Technology (ONC) has produced a risk assessment guide for small health care practices, called Reassessing Your Security Practices in a Health IT Environment, which is available at http://healthit.hhs.gov/portal/server.pt/gateway/PTARGS_0_10741_848086_0_0_18/SmallPracticeSecurityGuide-1.pdf.

The Healthcare Information and Management Systems Society (HIMSS), a private consortium of health care information technology stakeholders, created an information technology security practices questionnaire, available at <http://www.himss.org/content/files/ApplicationSecurityv2.3.pdf>. The questionnaire was developed to collect information about the state of IT security in the health care sector, but could also be a helpful self-assessment tool during the risk analysis process.

The Health Information Trust Alliance (HITRUST) worked with industry to create the Common Security Framework (CSF), a proprietary resource available at <http://hitrustcentral.net/files>. The risk management section of the document, Control Name: 03.0, explains the role of risk assessment and management in overall security

program development and implementation. The paper describes methods for implementing a risk analysis program, including knowledge and process requirements, and it links various existing frameworks and standards to applicable points in an information security life cycle.